Projeto Final

Implantação de arquitetura de Autenticação e Autorização para Gestão de Acessos de Aplicativos Web e Gerenciamento de APIs

Turma: CAIXAVERSO - 08 | Agente de Segurança Cibernética – II -1613

Modulo: Desenvolvimento Seguro de Aplicações I

Nome: Elias Carneiro Filho

Introdução

Esse documento apresenta o resultado do projeto final da ADA Tech para a FuturisTech S.A.

Como sou iniciante em cibersegurança, o foco é uma arquitetura **simples e prática** de autenticação e autorização para aplicativos web e APIs.

Explico de forma clara: como proteger logins, controlar acessos com papéis (RBAC), usar MFA e JWT, e identificar ameaças básicas.

Sumário

Sumário Executivo 04

1. Arquitetura do Projeto 05

2. Arquitetura de autenticação 06

3. Definição de tecnologias, protocolos e ferramentas 07

4. Mecanismos de Segurança 07

5. Modelagem de Ameaças 08

6. Documentação e Treinamento 09

Sumário Executivo

Arquitetura Simples de Autenticação e Autorização para Aplicativos Web e APIs

Cliente: FuturisTech S.A. | **Classificação:** Confidencial | **Versão:** 1.0 | **Data:** março de 2026

Contexto

A FuturisTech, empresa listada em bolsa, precisa proteger seus aplicativos web e APIs. O objetivo é controlar quem acessa os dados de forma segura e fácil para o usuário.

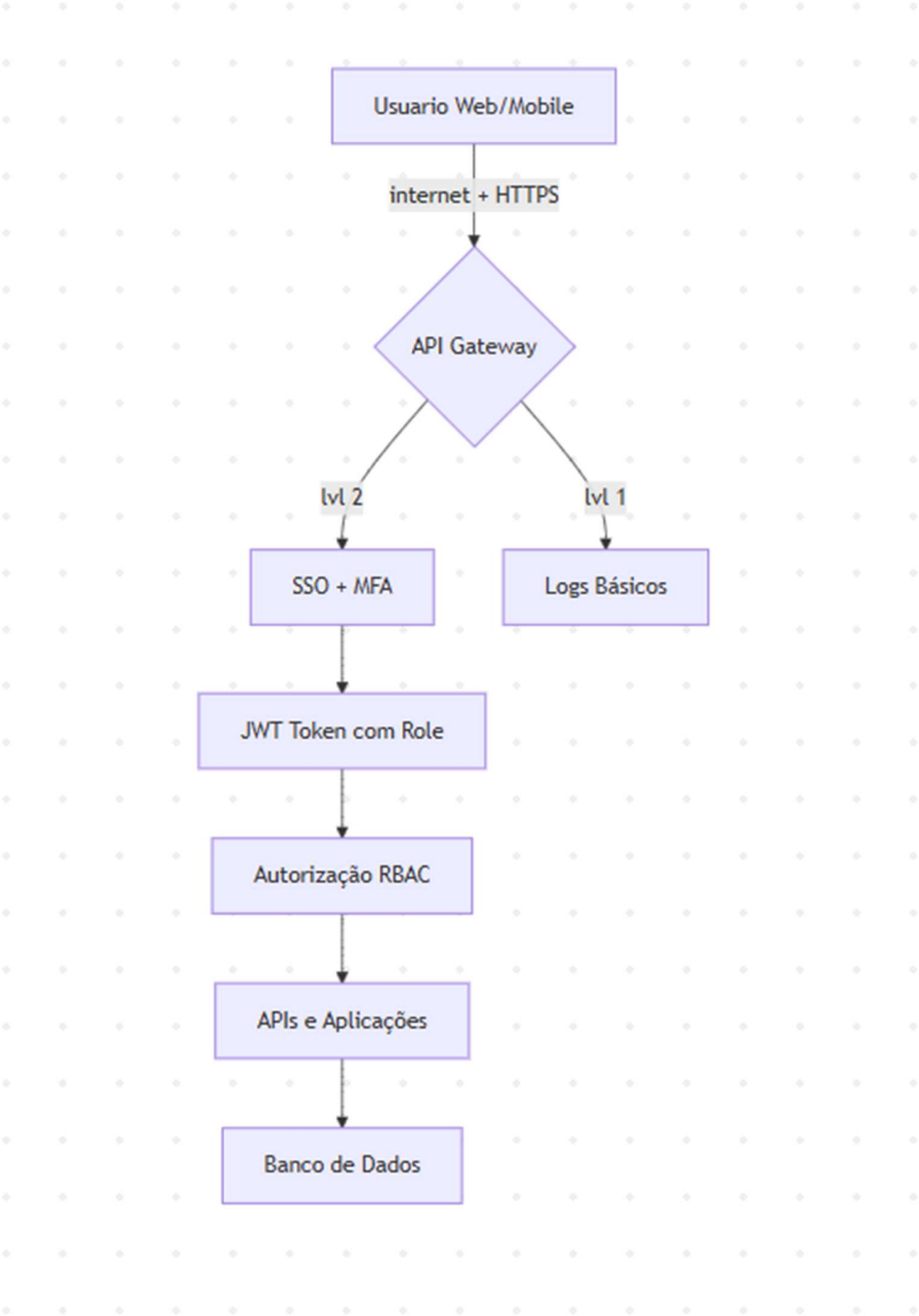
Escopo e Objetivos

1. Desenho básico de autenticação (SSO + MFA) e autorização (RBAC).
2. Tecnologias e protocolos fáceis (OAuth 2.0, JWT, HTTPS).
3. Mecanismos essenciais (hashing de senhas, logs, revogação de tokens).
4. Gerenciamento básico de APIs com rate limiting.
5. Onde guardar a documentação.

Resultado esperado: Uma solução segura, com proteção básica contra ataques comuns e experiência fluida para os usuários.

1. Arquitetura do Projeto

Desenho simples da arquitetura:



Componentes principais (simplificados):

• Login único (SSO) + código no celular (MFA)

• Papéis (RBAC): usuário normal e admin

• Tokens JWT para acessar as APIs

• Tudo protegido por HTTPS

• Gerenciamento de APIs: API Gateway simples (ex: NGINX ou Kong básico) integra autenticação (validação JWT), autorização (RBAC), rate limiting (ex: 100 req/min por usuário) e logs de monitoramento

Arquitetura de autenticação

1. Usuário acessa o app.

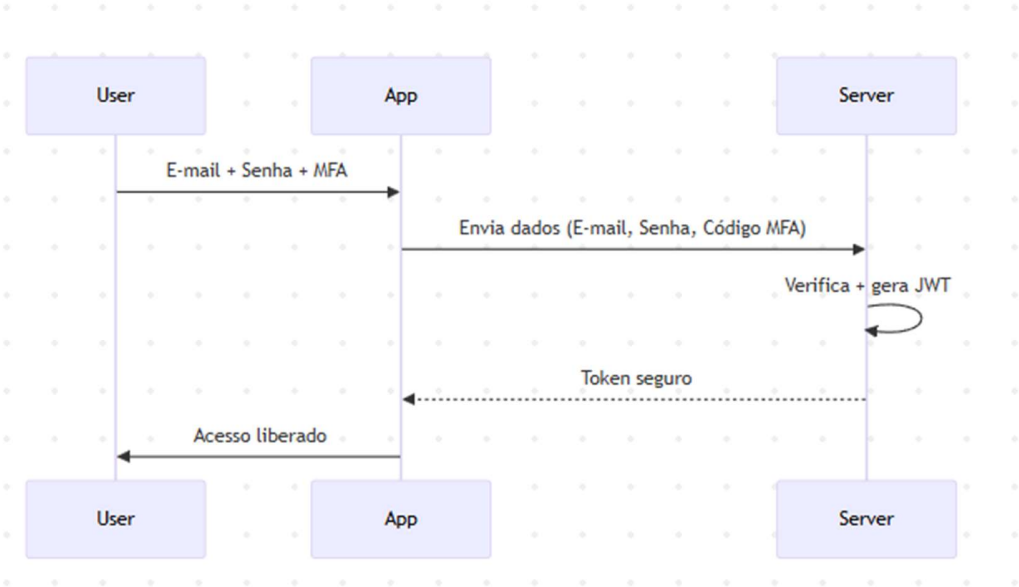
2. Faz login com e-mail + senha.

3. Recebe código MFA no celular (Google Authenticator).

4. Sistema gera JWT com o papel do usuário (ex: “admin”).

5. O token é usado para acessar páginas e APIs.

* Para colaboradores internos será utilizado Identity Federation via Azure AD (protocolo SAML 2.0), permitindo Single Sign-On (SSO) com as credenciais corporativas.



.

2. Definição de tecnologias, protocolos e ferramentas

Tecnologia / Conceito	Função Simples	Protocolo / Exemplo
JWT	Token para manter login seguro	JSON Web Token
OAuth 2.0 + OpenID Connect	Login único (SSO)	Padrão de autenticação
MFA (TOTP)	Código extra no celular	Google Authenticator
RBAC	Controle por papéis (user/admin)	Roles no sistema
HTTPS + TLS 1.3	Proteção da comunicação	Certificado SSL
Hashing de senhas	Armazenar senhas com segurança	bcrypt
Servidor de autenticação	Gerencia identidades e tokens	Ex: Keycloak ou Auth0 (básico)

3. Mecanismos de Segurança

• **Hashing de senhas:** Senhas nunca ficam legíveis (bcrypt).

• **MFA obrigatório:** Protege mesmo se senha for roubada.

• **Revogação de tokens em tempo real:** Bloqueio rápido de tokens roubados.

• **Logs de auditoria:** Registro simples de quem acessou o quê.

• **Detecção básica de anomalias:** Alerta se muitas tentativas erradas.

• **Rate limiting:** Limite de acessos para evitar ataques.

4. Modelagem de Ameaças

Mapeamento dos Trust Boundaries:

Usuário → Internet → API Gateway → Servidor → Banco de Dados

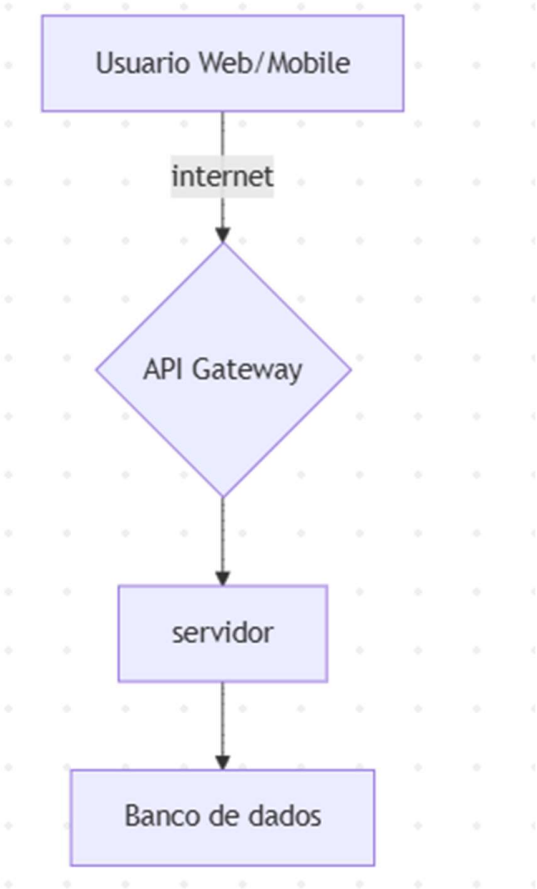


Tabela de Ativos

ID	Ativo	Classificação
A01	Senhas	Altamente Sensível
A02	JWT Tokens	Sensível
A03	Dados das APIs	Crítico

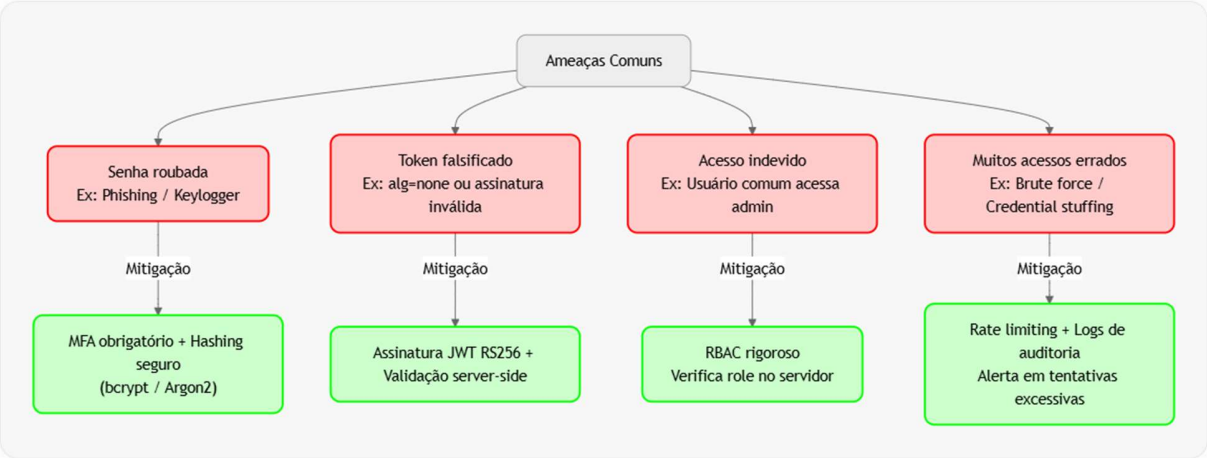
Ameaças comuns e proteção:

• Senha roubada → MFA + hashing

• Token falsificado → Assinatura JWT + validação

• Acesso indevido → RBAC (verifica papel no servidor)

• Muitos acessos errados → Rate limiting + logs



5. Documentação e Treinamento

Toda a arquitetura, fluxos, diagramas e práticas de segurança ficam armazenados no repositório oficial:

Local: Google Drive da FuturisTech → Pasta “Segurança da Informação” → “Projetos” → “Desenvolvimento Seguro de Aplicações I” → “Projeto Final – Elias Carneiro Filho

Treinamento: Sessão prática de 1 hora para a equipe de desenvolvimento com os seguintes tópicos:

- Como ativar e usar MFA com Google Authenticator

- Como validar JWT e aplicar RBAC no backend

- Importância do rate limiting e logs de auditoria.